ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Schneider Electric Modicon M340 PLC (BMX P34) · Component type: **Embedded Device (EDR) - programmable logic controller (legacy PAC)** · Target SL = SL 3

Where to work	**EcoStruxure Control Expert** (same tool as M580): **Security Editor** (user profiles + access rights), the project **application password** + file-encryption password, the CPU/NOE **Ethernet config** (Messaging › **Access Control** IP allow-list; Services = FTP/TFTP/HTTP/SNMP/EtherNet-IP enable-disable), and the **Memory Protect** physical input. No cyber rotary switch / IPsec / HTTPS on this platform.
Ports / paths	Modbus/**UMAS TCP 502** (unauthenticated); **HTTP 80** (embedded web, **no HTTPS**); **FTP 21** (off by default - keep off) + TFTP; **SNMP v1 UDP 161**; EtherNet/IP **44818** (via BMX NOC 0401). Config over Control Expert (Modbus/UMAS). No IPsec, no native Syslog.
Firmware / CVEs	Modicon **M340** CPUs **BMX P34 20•0 / 2030** (+ BMX NOE 0100/0110, NOC 0401). Patch the UMAS/Modbus auth-bypass issues - **CVE-2018-7842** (auth bypass by spoofing, CVSS 9.8) and **CVE-2021-22779 (ModiPwn)** - to CPU firmware **sv3.60+**; enforce the application password (the primary mitigation). Confirm CPU catalog + firmware in Control Expert.
How to read	Default read-only (Control Expert read-only .STU review + read-only Modbus/SNMP). Each row = native step-by-step + command-level external-tool validation + pass. Write/exploit tools = isolated env + written authorization. This is a legacy PAC: several rows are honestly Partial/Compensating.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the Control Expert (Unity) project (.STU) + archived application (.STA) and an .XEF/.ZEF export, **uploaded from the CPU**; the Security Editor / application & file passwords, Memory Protect + Ethernet Access-Control allow-list; the IO/module config; firmware rev; and the PLC diagnostic/event buffer.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / platform
SR/CR 1.1	Human user identification & auth	In Control Expert enable the **Security Editor** (Tools › Security Editor) so engineering access authenticates per user profile, and set the project **application password** (Project Settings / program protection) so opening/modifying the program requires it - this is the primary mitigation for the UMAS auth-bypass CVEs. **Test:** open/modify the .STU without the application password -> denied; each user is challenged. **Ext. tools:** Control Expert (Security Editor + application-password review); `nmap -p 502,80,44818 <ip>` (services in scope).	Per-user Security Editor + application password enforced; no anonymous program access.	EDR.
SR/CR 1.2	Device & software-process I&A	Native UMAS/Modbus are **unauthenticated**. Constrain who can connect using the Ethernet **Access Control** allow-list (CPU/NOE Ethernet config › Messaging › Access Control - enable + add authorized IP/subnet); there is **no IPsec** on M340, so segmentation + the app password are the compensating device-auth controls. **Test:** from a non-allow-listed IP, open a Modbus/UMAS connection -> refused. **Ext. tools:** `nmap --script modbus-discover -p 502 <ip>`; Wireshark filter `modbus` (UMAS); Modbus client from a non-listed IP (isolated) -> blocked.	Access-Control allow-list limits clients; unauthenticated UMAS compensated by ACL + app password + segmentation.	No IPsec - Partial/Compensating.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / platform
SR/CR 1.3	Account management	In the Security Editor review user profiles/roles - least privilege, named users, remove defaults, no shared logins. Custody of the Control Expert project (which holds security config). **Ext. tools:** Control Expert (Security Editor user list export); credential-custody record.	Named, least-privilege profiles; defaults removed; project protected.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers (Security Editor) and a unique device identity (IP, Modbus/EtherNet-IP address, CPU serial); no reuse across PLCs. **Ext. tools:** Control Expert device info; `nmap --script modbus-discover -p 502`; network inventory.	Unique user and device identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Confirm the **application password**, the **file-encryption password** (.STA/.STU/.ZEF), and the Security-Editor passwords are set and strong; change all defaults. Note: M340 password strength/policy is weaker than M580 - capture the enforced policy and compensate. **Ext. tools:** Control Expert (password/policy review).	Strong app/file/profile passwords set; defaults changed; policy captured.	Partial (legacy policy).
SR 1.6	Wireless access management	**N/A.** Wired PLC with no native wireless interface. **Ext. tools:** Confirm no wireless; upstream network governs.	N/A - justification recorded (wired device).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	**N/A / limited.** M340 has no device PKI/TLS (HTTP-only, no IPsec, no HTTPS). Record N/A; provide confidentiality/integrity via segmentation and TLS at the SCADA/EWS layer. **Ext. tools:** Confirm no configurable device certificate; Wireshark (web = HTTP cleartext).	N/A/limited device PKI; compensating TLS/segmentation upstream.	N/A/Partial.
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm Control Expert logon and the application-password entry mask the secret (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Control Expert Security Editor has **limited/no native lockout**; the PLC itself does not lock out Modbus/UMAS. Record the gap; compensate with the Access-Control allow-list, segmentation, and monitoring. **Ext. tools:** Repeated invalid logins (authorized) to characterize; IDS on the PLC segment.	Lockout where available; otherwise Partial + compensating (ACL/segmentation).	Known limitation.
SR/CR 1.12	System use notification	No native banner on the PLC/embedded web; enforce the approved use notice on the Control Expert EWS (GPO) and any SCADA HMI (compensating). **Ext. tools:** EWS `gpresult /h gp.html`; HMI banner review.	Use notice at EWS/HMI (compensating at PLC).	Compensating.
SR 1.13	Access via untrusted networks	Segment the PLC; firewall **502/TCP** (and 80/21/161/44818); no IPsec on M340 so use a **VPN** for cross-zone engineering; enable the Access-Control allow-list; no direct UMAS/Modbus from untrusted networks. **Test:** from an untrusted VLAN, reach 502 -> must fail. **Ext. tools:** `nmap -Pn -p 502,80,21,161,44818 <ip>` from the untrusted side (expect filtered); firewall + Access-Control review.	PLC unreachable from untrusted networks; brokered via VPN + ACL.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / platform
SR/CR 2.1	Authorization enforcement	In the Security Editor confirm per-user **access rights** (read / modify / debug / adjust / configure) follow least privilege; the **Memory Protect** input (below) blocks download regardless of login. **Test:** as a read-only user, attempt a download/config change -> denied. **Ext. tools:** Control Expert (access-rights review); attempt a privileged action as a read-only user (isolated).	Least privilege enforced per access right; privileged actions denied.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / platform
SR 2.3	Use control for portable/mobile devices	Control the Control Expert laptop and USB/SD (memory card) on the CPU; removable-media policy on the EWS; only authorized projects/firmware loaded; secure the CPU memory-card slot. **Ext. tools:** EWS removable-media policy; physical inspection of the CPU SD/memory card.	Portable/engineering media + memory card controlled.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code; confirm only the Control Expert application + firmware run; the embedded web content is vendor read-only (disable it if unused). **Ext. tools:** Control Expert (application review); browse the embedded web read-only; disable HTTP if unused.	Only the trusted application/firmware runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	No PLC-side idle lock; enforce workstation lock on the Control Expert EWS (OS screen lock/GPO). **Ext. tools:** EWS inactivity-lock GPO review.	Engineering workstation locks on inactivity (compensating at PLC).	Compensating.
SR/CR 2.6	Remote session termination	Confirm Control Expert / Modbus sessions can be closed and idle sessions end; the CPU bounds concurrent Modbus/UMAS connections (connection limit) so simultaneous conflicting programming is prevented. **Ext. tools:** Control Expert connection review; Wireshark (session teardown / connection count).	Sessions terminable; concurrency bounded/monitored.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	M340 has **no native Syslog security logging** (unlike M580). Capture configuration changes and attribution in Control Expert (project change records / audit where available) and log Modbus/connection events at the SCADA + a network IDS; forward to the SIEM. **Ext. tools:** Control Expert change records; network IDS/SIEM on the PLC segment (Modbus/UMAS connection + write events).	Changes recorded in Control Expert; PLC events captured by IDS/SCADA; attribution at the tool layer.	No native syslog - Compensating.
SR/CR 2.9	Audit storage capacity	Because logging is off-device (SCADA/IDS/SIEM), confirm those are sized/retained and alert on collection failure so PLC-related events are not silently lost. **Ext. tools:** SIEM/IDS retention + source-silent alert review.	Off-device logs sized/retained; audit-failure alerting defined.	Compensating.
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the CPU/system time is synced (NTP to the CPU/NOE where supported, or via the SCADA) so event timestamps are accurate and correlate. **Ext. tools:** Control Expert time config; `nmap -sU -p 123` / Wireshark `ntp`.	Reliable, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: locked cabinet; secure the CPU **USB/Modbus console** and the **SD memory card**; wire and activate the **Memory Protect** input (a configured %I bit) so program download/online-modify is physically inhibited when set; disable unused services. **Ext. tools:** Physical inspection; Control Expert (Memory Protect input configured/active; unused services off).	Physical/diagnostic interfaces controlled; Memory Protect active; unused services disabled.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / platform
SR/CR 3.1	Communication integrity	UMAS/Modbus + the embedded web are **unauthenticated cleartext** and M340 has **no IPsec/HTTPS** - so integrity/confidentiality come from **containment**: keep UMAS/Modbus/web inside a segmented cell zone, use a VPN for cross-zone, and terminate any TLS at the SCADA layer. Confirm no cleartext control protocol crosses a zone boundary. **Test:** confirm Modbus/UMAS/web stay in-zone (no cleartext crossing the boundary). **Ext. tools:** Wireshark `modbus || http` (cleartext, in-zone only); firewall rule review.	Control comms contained/segmented; no cleartext across boundaries (no native crypto).	No IPsec/HTTPS - Compensating.
SR/EDR 3.2	Protection from malicious code (component)	Confirm only Schneider firmware runs and there is no code path beyond the application. Patch the CVE-affected firmware to **sv3.60+**; obtain firmware from Schneider and verify provenance. (No signed-boot guarantee like modern platforms - provenance discipline is the control.) **Ext. tools:** Control Expert (firmware version vs sv3.60+); Schneider provenance/hash check; Schneider CPP/SEVD advisory review.	Only vendor firmware runs; CVE-patched (sv3.60+); provenance verified.	EDR-specific/Partial.
SR/CR 3.3	Security functionality verification	After any change re-verify: Security Editor on, application password set, Access-Control allow-list, services disabled (FTP/TFTP/HTTP/SNMP as unused), Memory Protect active, firmware patched, against the hardening baseline; compare the Control Expert project. **Ext. tools:** Control Expert (settings vs baseline .STU); `nmap -p 502,80,21,161,44818 <ip>` (only required reachable).	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm program/config integrity: application password + file-encryption + Memory Protect prevent unauthorized program change; archive the .STU and use change detection to detect drift. Compare online-vs-offline. **Ext. tools:** Control Expert (online-vs-offline compare); `certutil -hashfile app.sta SHA256` for drift.	Program integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Confirm the CPU tolerates malformed Modbus/UMAS/EtherNet-IP frames without faulting. **ISOLATED only:** fuzz the Modbus/UMAS interface on a bench CPU and watch scan/CPU/connection health (note the known UMAS auth-bypass PoCs - test only in a lab). **Ext. tools:** Modbus/UMAS fuzzer (`boofuzz`) on a bench CPU; Wireshark; watch the CPU diagnostic/fault state.	No crash or loss of control on malformed input.	Do NOT fuzz an in-service CPU.
SR/CR 3.6	Deterministic output	Verify configured fail-safe behavior: output-module fallback (hold-last / preset) on CPU STOP or comm loss, and the CPU behavior on fault, so outputs assume a defined safe state. **Ext. tools:** Control Expert (I/O fallback / hold-last-state config); simulate CPU STOP / comm loss -> defined output state.	Outputs go to a defined/fail-safe state on fault or comm loss.	
SR/CR 3.7	Error handling	Confirm graceful fault handling (CPU diagnostic/system words + fault behavior, no unsafe auto-restart) so errors do not cause loss of control or info leak. **Ext. tools:** Control Expert (diagnostics / system words; fault behavior review).	Graceful fault handling; no unsafe restart or info leak.	
SR/CR 3.8	Session integrity	**N/A / limited.** No secured (authenticated/encrypted) session (unauthenticated UMAS/Modbus, no IPsec); integrity provided by containment. Record N/A + compensating segmentation. **Ext. tools:** Wireshark (confirm in-zone containment).	N/A/limited at device; compensating segmentation recorded.	N/A/Partial.
SR/CR 3.9	Protection of audit information	Since audit is off-device, protect the SCADA/IDS/SIEM store and the Control Expert change records; restrict who can read/clear them. **Ext. tools:** SIEM/SCADA access review; Control Expert project access.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Update firmware via Control Expert / Unity Loader with firmware from Schneider; verify version/provenance; plan the update in a maintenance window with a rollback to the prior version; apply the CVE-fix firmware (sv3.60+). **Ext. tools:** Unity Loader / Control Expert (update flow); Schneider provenance/version + SEVD advisory.	Controlled updates from a verified source, CVE-patched, with rollback.	EDR-specific/Partial.
EDR 3.11	Physical tamper resistance/detection	Keep the CPU in a locked/sealed cabinet; control the SD memory card, USB/console, and terminals; the Memory Protect input adds tamper resistance; config changes visible in Control Expert; seal where required. **Ext. tools:** Physical inspection (cabinet/seal, memory-card, Memory Protect); Control Expert change review.	Cabinet locked/sealed; interfaces controlled; Memory Protect set; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	**Partial/N-A at device.** M340 has no documented signed-boot supplier root of trust. Record the gap; compensate via firmware-provenance discipline (3.10), CVE patching, physical control, and segmentation. **Ext. tools:** Confirm no secure-boot/signed-firmware root; provenance process review.	No documented supplier RoT; compensating controls recorded.	Partial/N-A.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / platform
EDR 3.13	Provisioning asset-owner roots of trust	**Partial/N-A at device.** No asset-owner certificate provisioning (no IPsec/PKI on M340). Record the gap; asset-owner trust enforced at the network layer (VPN/firewall) and by segmentation. **Ext. tools:** Confirm no device certificate/IPsec provisioning; segmentation review.	No asset-owner RoT; compensating controls recorded.	Partial/N-A.
EDR 3.14	Integrity of the boot process	**Partial/N-A at device.** No published verified/secure boot. Record the gap; mitigate via controlled firmware provenance (3.10), CVE patching, physical control, and monitoring. **Ext. tools:** Confirm no secure-boot capability; Control Expert firmware version.	No documented verified boot; compensating controls recorded.	Partial/N-A.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / platform
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, clear the CPU program/memory (Control Expert - clear/initialize), erase/destroy the **SD memory card**, and remove exported projects/backups so program and configuration are not recoverable. **Ext. tools:** Control Expert (clear controller); memory-card sanitize/destroy.	Program/config purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	**N/A / limited.** The only device crypto is the file-encryption password on the project files; there is no comms crypto (no IPsec/HTTPS). Rely on TLS at the SCADA/EWS layer and segmentation; disable the embedded web if unused. **Ext. tools:** Confirm file-encryption password set; confirm no comms crypto; disable HTTP if unused.	File encryption used; no comms crypto - compensating TLS/segmentation upstream.	N/A/Partial.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / platform
SR/CR 5.1	Network segmentation	Primary control. Confirm the PLC sits in a segmented cell zone behind a firewall; only required protocols cross (Modbus 502, EtherNet/IP 44818 to authorized peers); the Access-Control allow-list is enabled; no flat convergence with IT; VPN for cross-zone. **Ext. tools:** `nmap -p 502,80,21,161,44818 <ip>` per zone; firewall/ACL + Access-Control review.	PLC in a segmented zone; only required flows cross the boundary; ACL enabled.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Single-purpose controller with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services on the PLC.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	**N/A.** Single-purpose PLC; no separable applications to partition. **Ext. tools:** Confirm single-function device.	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / platform
SR/CR 6.1	Audit log accessibility	Since M340 has no native Syslog, monitoring is off-device: confirm the SCADA and a passive **OT IDS** (Modbus/UMAS-aware) on the PLC segment capture connection/write/CVE-exploitation events and forward to the SIEM; Control Expert change records are exportable. **Ext. tools:** Passive OT IDS (Nozomi/Dragos, Modbus/UMAS-aware) on a SPAN; SIEM; Control Expert change export.	PLC events monitored off-device in near-real-time; changes exportable.	No native syslog - Compensating.
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / platform
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: the CPU Modbus connection limits + cell-firewall rate-limiting prevent a flood from denying control; M340 is sensitive to Modbus/scan storms, so confirm firewall rate controls and monitor scan/CPU load. **Ext. tools:** ISOLATED bench: `hping3 --flood -p 502 <ip>` / Modbus storm; watch CPU scan time + connection state.	Resources bounded; control continues under load.	
SR/CR 7.2	Resource management	Confirm bounded resources (max Modbus connections, comms load, scan-time monitoring) so a single service cannot starve control. **Ext. tools:** Control Expert (connection/comms load; scan time); bench load test.	Resources bounded; no exhaustion-based loss of control.	
SR/CR 7.3	Control system backup	Confirm the Control Expert application (.STU/.STA) + CPU config are backed up (versioned, offline) and a restore is tested on a spare CPU for a known-good rebuild. **Ext. tools:** Backup repository review; restore test (spare CPU).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden per the Cyber Security Reference Manual: enable the Security Editor + application password, enable the Access-Control allow-list, **disable unused services** (FTP/TFTP - off by default; HTTP web if unused; SNMP v1 or restrict), activate Memory Protect, and patch firmware. **Ext. tools:** Control Expert (services/ACL/Memory Protect config); `nmap -sTU -p 21,80,161,502,44818 <ip>` (only required reachable).	Least functionality; unused services disabled per the reference manual.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm the CPU (BMX P34 catalog, firmware version, NOE/NOC modules) is inventoried so vulnerabilities track against Schneider SEVD advisories / CISA ICS advisories (M340 has several). **Ext. tools:** `nmap --script modbus-discover -p 502`; Control Expert inventory; Schneider SEVD feed.	Accurate CPU/module/firmware inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
EcoStruxure Control Expert	Native config & protection review (all FRs)	Open the .STU read-only; Tools › Security Editor (profiles/access rights); Project Settings (application + file passwords); CPU/NOE Ethernet config (Messaging › Access Control; Services); Memory Protect input; firmware version. Export as the baseline.	Read/authorized project copy.
Unity Loader	Firmware update & provenance (3.2, 3.10)	Update the CPU to CVE-fixed firmware (sv3.60+) from a Schneider-verified file; confirm version/provenance; keep the prior version for rollback.	Maintenance window.
nmap	Port/service exposure, Modbus ID & segmentation (1.x, 3.1, 5.x, 7.6, 7.8)	`nmap -p 502,80,21,161,44818 <ip>`; `nmap --script modbus-discover -p 502 <ip>` (unit IDs); scan per zone for segmentation.	Read-only; authorized.
Wireshark / tcpdump	Comms integrity & identity (1.2, 3.1, 3.8)	Filter `modbus || http`; confirm cleartext control/web stay in-zone; inspect UMAS function codes and connection setup.	Passive; SPAN/tap only.
Modbus/UMAS client (isolated)	Auth & authorization tests (1.2, 2.1)	From a non-allow-listed IP attempt a Modbus/UMAS connection/write -> blocked; confirm the application password blocks unauthorized program actions.	ISOLATED/authorized; never on a live CPU.
Modbus/UMAS fuzzer / hping3	Input validation & DoS resilience (3.5, 7.1)	`boofuzz` Modbus/UMAS on a bench CPU; `hping3 --flood -p 502 <ip>` storm; watch scan time + connection state.	ISOLATED bench; written authorization.
Passive OT IDS (Modbus/UMAS-aware)	Monitoring (2.8, 6.x) - replaces native syslog	Nozomi/Dragos on a SPAN port to capture Modbus/UMAS connection/write and CVE-exploitation attempts; forward to the SIEM.	Passive; coordinate with SOC.
Schneider SEVD / CISA advisories	Vuln tracking (3.2, 3.10, 7.8)	Track M340 advisories (CVE-2018-7842, CVE-2021-22779 ModiPwn, NOE/NOC CVEs) and required firmware.	Reference.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.